Password Policy Audit & Modernized Framework

Executive Summary

Traditional password policies often rely on complex, burdensome rules (such as mandatory frequent expiration and strict special character requirements) that inadvertently encourage insecure user behaviors like writing passwords on sticky notes, reusing credentials, or making predictable incremental changes (e.g., Password1!, Password2!). This document provides a complete audit of a legacy sample password policy against modern NIST SP 800-63B guidelines, establishes an improved user-friendly policy, and includes a one-page staff guide designed to make safe behavior the easiest behavior.

1. Audit of the Sample Password Policy

The table below evaluates legacy sample password rules against modern NIST digital identity guidelines and practical security principles.

Old Sample Rule	Verdict	Detailed Reason & NIST-Style Analysis
At least 8 characters	Change	**Length matters more than complexity.** Modern standards recommend a minimum length of 12 characters to resist brute-force cracking. 8 characters is too easily computed by modern processing power.
Must include a symbol	Remove	**Complexity rules backfire.** Forcing symbols leads users to append predictable characters like '!' or '@' at the end of words (e.g., "Password!"), which automated crackers easily anticipate.
Change every 30 days	Remove	**Friction causes poor habits.** Frequent mandatory rotation forces users to create small,

Old Sample Rule	Verdict	Detailed Reason & NIST-Style Analysis
		predictable variations of existing passwords (Password1, Password2) or reuse them across systems. NIST advises against forced rotation unless a breach is suspected.
No spaces allowed	**Remove**	**Blocks passphrases.** Prohibiting spaces prevents users from utilizing long, highly secure passphrases (e.g., "correct horse battery staple"), which are significantly easier to remember and harder to crack.
Block pasting passwords	**Remove**	**Stifles password managers.** Blocking paste functionality directly prevents staff from using password managers, forcing them to memorize or manually type weak, short passwords.

2. The Improved, Modern Password Policy

Designed around NIST SP 800-63B guidance, this policy eliminates counterproductive friction while strengthening organizational security.

- **Length Over Complexity:** Use a passphrase or password of at least **12 characters**. Length significantly outweighs arbitrary composition rules.
- **Allow Passphrases & Pasting:** Spaces and symbols are fully permitted. Paste functionality is enabled on all login portals to support password managers.
- **No Forced Expiration:** Passwords do not expire on a rigid schedule. Passwords are only required to be changed if there is evidence of a breach or compromise.
- **Mandatory Breach Screening:** All new or changed passwords are automatically checked against public databases of known breached credentials (via Have I Been Pwned API integration) to block compromised phrases.
- **Strict Credential Isolation:** Never reuse the same password or passphrase across personal accounts and company systems, or across multiple internal applications.
- **Mandatory Password Manager:** All employees must utilize the company-approved password manager (such as Bitwarden) to generate and store unique, complex credentials.

- **Two-Step Verification (2FA):** Multi-factor authentication must be enabled on all corporate email accounts, financial portals, and sensitive internal systems.

3. One-Page Staff Guide: Secure Your Accounts in 3 Simple Steps

This guide is designed for non-technical staff to follow effortlessly.

Step 1: Use the Company Password Manager

- **What to do:** Install and log into the approved company password manager (Bitwarden). Let it generate and remember long, unique passwords for every site you use.
- **Why it matters:** You only ever need to remember **one** master passphrase. It stops password reuse and protects you even if one website is compromised.

Step 2: Embrace Long Passphrases (Spaces Welcome!)

- **What to do:** When creating a master passphrase, use 4 or more random words combined with spaces (e.g., "correct coffee mountain paper").
- **Why it matters:** Length beats complexity. Long phrases are much easier for your brain to remember, yet practically impossible for hackers to guess or brute-force.

Step 3: Turn on Two-Step Verification (2FA)

- **What to do:** Enable 2FA (via authenticator app or hardware security key) on your work email, cloud storage, and banking logins.
- **Why it matters:** Even if a hacker steals your password, they cannot access your account without your secondary verification device.

4. References & Trusted Sources

- **NIST SP 800-63B:** Digital Identity Guidelines - Authentication and Lifecycle Management (nist.gov)
- **Have I Been Pwned:** Pwned Passwords API & Guidance (haveibeenpwned.com)
- **US CISA:** Choosing and Protecting Passwords Guidance (cisa.gov)